

# Cyber Risk Assessment & Risk Management Policy

Hewlett Packard Enterprise (HPE)

Document Owner: Global Chief Information Security Officer (CISO)

Classification: HPE Internal

Version: 4.2 | Effective Date: 2026-01-15 | Next Review: 2027-01-15

---

## 1. Purpose

This policy establishes the enterprise-wide methodology by which Hewlett Packard Enterprise identifies, analyzes, evaluates, and treats cyber risk across its global operations. It ensures that risk-based decisions protecting HPE GreenLake edge-to-cloud services, Aruba networking, ProLiant compute infrastructure, and the SAP S/4HANA ERP environment are consistent, defensible, and aligned with the corporate risk appetite approved by the Board Audit Committee.

## 2. Scope

This policy applies to all HPE business units, subsidiaries, and third-party service providers worldwide. The assessment scope encompasses all information assets, production and non-production systems, cloud tenancies, and OT/IoT boundaries that store, process, or transmit HPE or customer data. Explicit scope boundaries are documented for each assessment engagement, including the GreenLake control plane, Aruba Central management infrastructure, ProLiant firmware supply chain, and the SAP S/4HANA financial and manufacturing modules. Assets are enumerated from the authoritative Configuration Management Database (CMDB) prior to each cycle.

## 3. Risk Assessment Methodology

HPE applies a structured risk framework aligned to NIST SP 800-30, NIST CSF 2.0, and ISO/IEC 27005. The assessment process follows five phases: (1) asset and system characterization, (2) threat and vulnerability identification, (3) inherent risk analysis, (4) control evaluation and residual risk determination, and (5) risk treatment and reporting.

### 3.1 Risk Scoring

Each identified risk is scored on two dimensions:

- Likelihood / Probability - the assessed probability that a given threat will successfully exploit a vulnerability, rated on a 1-5 scale informed by current threat intelligence, historical incident data, and control maturity.
- Impact / Consequence - the severity and magnitude of harm to HPE should the risk materialize, evaluated across financial, operational, regulatory, safety, and brand-reputation consequence categories, also rated 1-5.

The product of likelihood and impact yields the inherent (gross) risk rating - the exposure calculated *\*before\** the application of mitigating controls. After accounting for the design and operating effectiveness of existing controls, a residual (net) risk rating is derived, representing the remaining exposure retained by HPE.

## 4. Assessment Cadence

Risk assessments are conducted on a defined schedule to maintain currency:

- Annual enterprise-wide risk assessment covering all in-scope business units and crown-jewel systems.
- Quarterly assessments for high-criticality environments, including the GreenLake control plane and SAP S/4HANA.
- Event-driven / periodic assessments triggered by material change - new product launches, mergers and acquisitions, significant architecture changes, or emerging zero-day threats.

## **5. Threat Intelligence Integration**

Risk analysis is enriched by HPE's Cyber Threat Intelligence (CTI) function, which continuously profiles relevant adversary groups, attack campaigns, and tactics, techniques, and procedures (TTPs) mapped to the MITRE ATT&CK framework. Intelligence is aggregated from multiple sources and feeds, including CISA advisories and Known Exploited Vulnerabilities catalog, sector ISAC memberships (IT-ISAC), commercial vendor intel subscriptions, open-source feeds, and internal telemetry from Aruba and GreenLake sensors. This threat intelligence directly informs likelihood scoring and ensures that assessments reflect the active adversary landscape targeting the technology sector.

## **6. Risk Register**

All identified risks are recorded in the enterprise Risk Register, the authoritative inventory and catalog of cyber risk maintained within the HPE GRC platform. Each register entry captures the asset affected, threat scenario, inherent and residual scores, assigned controls, treatment decision, target remediation date, and status. The Risk Register is reviewed monthly by the Cyber Risk Council and reported quarterly to executive leadership.

## **7. Risk Appetite and Tolerance**

The Board-approved risk appetite defines the level of cyber risk HPE is willing to accept in pursuit of its business objectives. Quantitative risk tolerance thresholds are established per risk tier: residual risks scoring within the "Low" band fall inside tolerance and may be formally accepted, while risks exceeding defined thresholds require documented treatment plans and executive sign-off. Any acceptance of risk above tolerance requires explicit approval from the CISO and the relevant Business Unit executive.

## **8. Risk Ownership and Accountability**

Every risk in the register is assigned a named Risk Owner - the accountable business or technical leader responsible for the affected asset and for driving the treatment decision to completion. The CISO organization provides oversight, facilitation, and challenge, but accountability for accepting or remediating a risk rests with the designated responsible party. Ownership assignments are validated during each assessment cycle.

## **9. Risk Treatment**

For each risk exceeding tolerance, the Risk Owner, supported by the security team, selects one or more treatment strategies:

- Mitigate / Remediate - implement or strengthen technical and administrative controls to reduce likelihood or impact (the default and preferred response).
- Transfer - shift financial exposure through cyber insurance or contractual indemnification

with suppliers and partners.

- Accept - formally retain the residual risk where it is within appetite, with documented rationale and time-bound review.
- Avoid - eliminate the risk by discontinuing the associated activity, system, or process.

Treatment progress is tracked to closure in the Risk Register, and the effectiveness of implemented controls is re-validated in the subsequent assessment to confirm that residual risk has been reduced to an acceptable level.

## **10. Governance and Review**

This policy is owned by the Global CISO and reviewed at least annually, or upon significant regulatory or business change. Exceptions require formal approval through the HPE Security Exception process. Non-compliance may result in disciplinary action consistent with HPE's Standards of Business Conduct.

---

\* Hewlett Packard Enterprise. This document is HPE Internal and subject to controlled distribution.\*